

Denah Compliance UU Pelindungan Data Pribadi

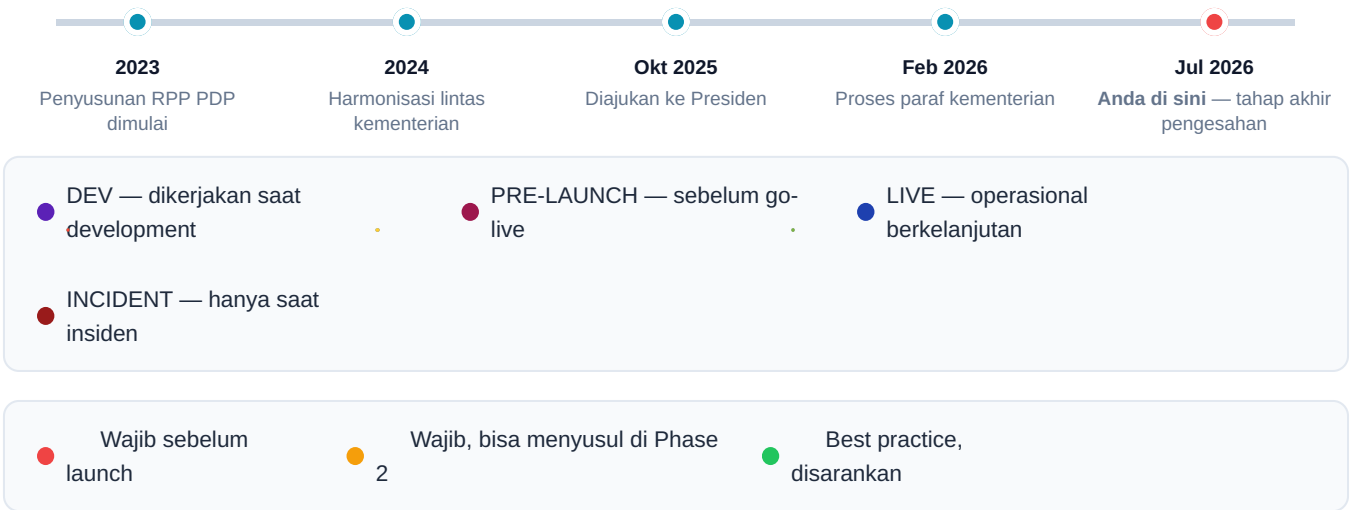
Peta pasal-ke-eksekusi untuk platform social trading —
menghubungkan kewajiban hukum dengan langkah konkret di
development, pre-launch, dan operasional harian.



Status Hukum & Cara Membaca Dokumen

Konteks regulasi terkini dan panduan simbol yang dipakai di seluruh dokumen

UU No. 27/2022 sudah berlaku penuh sejak 17 Oktober 2022. Peraturan Pemerintah (PP) turunannya masih dalam proses pengesahan — namun ketiadaan PP tidak menghapus kewajiban yang sudah eksplisit di level UU (misalnya kewajiban DPIA di Pasal 34, berlaku sejak 17 Oktober 2024).



Daftar Isi

1	Consent & Dasar Pemrosesan Pasal 9, 20-24, 40	2	Data Spesifik & DPIA Pasal 4, 34
3	Keamanan Teknis Data Pasal 31, 35-39	4	Hak Subjek Data & SLA Pasal 6-8, 13, 14, 30, 32
5	Kegagalan Perlindungan Data Pasal 46	6	Transfer ke Pihak Ketiga Pasal 16, 55, 56, 65
7	Data Anak & Disabilitas Pasal 25	8	Retensi & Penghapusan Pasal 16, 44
9	Governance Internal Pasal 53, 54	★	Ringkasan Roadmap MVP → Phase 2 → Phase 3

1

Consent & Dasar Pemrosesan Data

Bagaimana persetujuan user harus diminta, disimpan, dan dihormati

Pasal 20(2)a

DEV

Wajib

KETENTUAN INTI

Dasar pemrosesan = persetujuan eksplisit dari user

LANGKAH EKSEKUSI

Halaman onboarding dengan checkbox **terpisah per tujuan** — bukan satu checkbox "Setuju S&K"

Pasal 22(1-3)

DEV

Wajib

KETENTUAN INTI

Persetujuan wajib tertulis/terekam, kekuatan hukum sama baik elektronik/nonelektronik

LANGKAH EKSEKUSI

Simpan tiap consent ke tabel `user_consent`: `user_id`, `consent_type`, `versi_kebijakan`, `timestamp`, `ip_address`, `status`

Pasal 22(4)

DEV

Wajib

KETENTUAN INTI

Jika consent memuat tujuan lain, harus dibedakan jelas & bahasa sederhana

LANGKAH EKSEKUSI

Pisahkan minimal 3 consent: (1) koneksi MT5 read-only, (2) tampil di dashboard pribadi, (3) share ke signal feed publik/PAMM

Pasal 22(5)

PRE-LAUNCH

Wajib

KETENTUAN INTI

Consent yang tidak memenuhi syarat di atas **batal demi hukum**

LANGKAH EKSEKUSI

Legal/QA review teks consent sebelum launch — pastikan tidak ada bundling consent

Pasal 21

DEV

Wajib

KETENTUAN INTI

Wajib sampaikan info: legalitas, tujuan, jenis data, retensi, durasi, hak subjek — sebelum consent diminta

LANGKAH EKSEKUSI

Halaman "Informasi Pemrosesan Data" wajib dibaca/scroll sebelum tombol consent aktif

Pasal 21(2)

LIVE

Phase 2

KETENTUAN INTI

Perubahan tujuan/kebijakan wajib diberitahu **sebelum** berlaku

LANGKAH EKSEKUSI

Sistem notifikasi in-app + email untuk perubahan kebijakan, dengan re-consent flow bila perlu

Pasal 24

LIVE

Wajib

KETENTUAN INTI

Pengendali wajib bisa **menunjukkan bukti** consent yang diberikan

LANGKAH EKSEKUSI

Admin panel untuk export riwayat consent per user (untuk audit/ permintaan regulator)

Pasal 9 & 40

DEV

Wajib

KETENTUAN INTI

User berhak tarik consent kapan saja; pemrosesan wajib dihentikan maks **3×24 jam**

LANGKAH EKSEKUSI

Toggle di setting profil + job/queue otomatis yang stop-processing begitu status = revoked

2

Data Spesifik & Penilaian Risiko (DPIA)

Data keuangan pribadi butuh perlakuan lebih ketat dari data umum

Pasal 4(2)f

DEV

Wajib

KETENTUAN INTI

Data keuangan pribadi (saldo, P/L, posisi) = **Data Pribadi spesifik**

LANGKAH EKSEKUSI

Tandai kolom balance/equity/open positions/riwayat transaksi sebagai "sensitive field" — level enkripsi & akses beda dari data umum

Pasal 34(1-2)

PRE-LAUNCH

Wajib

KETENTUAN INTI

Wajib DPIA jika risiko tinggi: data spesifik, skala besar, profiling otomatis, teknologi baru

LANGKAH EKSEKUSI

Susun DPIA internal sebelum launch: identifikasi risiko + mitigasi. Format bebas (PP belum terbit) — cukup terdokumentasi

Pasal 34(2)d

DEV

Phase 2

KETENTUAN INTI

Auto-signal generation (deteksi posisi baru otomatis) = "pemantauan sistematis" → risiko tinggi

LANGKAH EKSEKUSI

Saat bangun fitur ini, masukkan ke DPIA sebagai item risiko baru sebelum fitur live

Pasal 4(3)f

DEV

Phase 2

KETENTUAN INTI

Data kombinasi identifikasi (no. telp, IP address) juga termasuk Data Pribadi

LANGKAH EKSEKUSI

IP/device fingerprint untuk fraud detection tetap masuk kebijakan retensi & consent yang sama

3

Keamanan Teknis Data

Pasal 31, 35-39 — implementasi konkret di infrastruktur Anda

Pasal 35a

DEV

Wajib

KETENTUAN INTI

Wajib langkah teknis operasional melindungi data

LANGKAH EKSEKUSI

Enkripsi **at-rest** untuk kolom sensitif (investor password MT5, saldo) — AES-256 atau setara, bukan plaintext

Pasal 35b

DEV

Wajib

KETENTUAN INTI

Tingkat keamanan disesuaikan sifat & risiko data

LANGKAH EKSEKUSI

Investor password MT5 → simpan di secrets manager (HashiCorp Vault/AWS Secrets Manager), bukan kolom biasa

Pasal 36

DEV

Wajib

KETENTUAN INTI

Wajib jaga kerahasiaan data

LANGKAH EKSEKUSI

RBAC: admin support tidak bisa lihat password mentah, hanya sistem yang bisa decrypt saat connect ke bridge

Pasal 37

LIVE

Phase 2

KETENTUAN INTI

Wajib awasi semua pihak yang terlibat dalam pemrosesan

LANGKAH EKSEKUSI

Audit log setiap akses ke data sensitif — siapa akses siapa, kapan, termasuk tim internal

Pasal 38-39

DEV

Wajib

KETENTUAN INTI

Cegah akses tidak sah; proses via sistem "andal, aman, bertanggung jawab"

LANGKAH EKSEKUSI

TLS 1.2+ semua komunikasi · MFA akun admin · rate limiting & WAF · vulnerability scanning berkala

Pasal 39

DEV

Wajib

KETENTUAN INTI

Berlaku khusus untuk VPS Windows tempat MT5 bridge berjalan

LANGKAH EKSEKUSI

Firewall ketat (hanya port yang perlu terbuka), disable RDP publik, patch OS rutin

Pasal 31

PRE-LAUNCH

Phase 2

KETENTUAN INTI

Wajib rekam seluruh kegiatan pemrosesan (mirip ROPA)

LANGKAH EKSEKUSI

Dokumen internal ROPA: daftar tempat data pribadi diproses (tabel DB, log file, cache, API pihak ketiga)

4

Hak Subjek Data & SLA Teknis

Kewajiban dengan tenggat waktu eksplisit — bukan sekadar prinsip

Pasal 7

DEV

Phase 2

KETENTUAN INTI

User berhak akses & salinan data pribadinya

LANGKAH EKSEKUSI

Endpoint GET `/api/user/my-data/export` — generate JSON/PDF semua data pribadi user

Pasal 32(2)

DEV

Phase 2

KETENTUAN INTI

Akses wajib diberikan maks **3×24 jam** sejak diminta

LANGKAH EKSEKUSI

Jika belum full-automated: tiket otomatis ke admin dengan SLA countdown 72 jam

Pasal 6 & 30

DEV

Phase 2

KETENTUAN INTI

User berhak koreksi data; wajib diperbaiki maks **3×24 jam**

LANGKAH EKSEKUSI

Edit profil self-service untuk data umum; request queue SLA 72 jam untuk data yang butuh verifikasi

Pasal 8 & 43

DEV

Wajib

KETENTUAN INTI

User berhak minta hapus data; wajib dihapus jika diminta

LANGKAH EKSEKUSI

Endpoint "Delete Account" — hard delete/anonymize, sesuaikan kewajiban retensi lain (audit keuangan)

Pasal 13

DEV

Disarankan

KETENTUAN INTI

Berhak dapat data dalam format portabel

LANGKAH EKSEKUSI

Export JSON/CSV, bukan hanya screenshot/PDF read-only

Pasal 14

DEV

Phase 2

KETENTUAN INTI

Pelaksanaan hak user via "permohonan tercatat"

LANGKAH EKSEKUSI

In-app request form + ticket ID — bukan chat WhatsApp informal

5

Kegagalan Perlindungan Data (Data Breach)

Pasal 46 — siapkan sebelum insiden, bukan saat insiden

Pasal 46(1)

INCIDENT

Wajib

KETENTUAN INTI

Notifikasi tertulis maks **3×24 jam** ke user & lembaga (saat ini: Kemkomdigi)

LANGKAH EKSEKUSI

Siapkan **incident response playbook**: template notifikasi, kontak Kemkomdigi, eskalasi internal

Pasal 46(2)

INCIDENT

Wajib

KETENTUAN INTI

Notifikasi minimal memuat: data yang bocor, kapan/ bagaimana, upaya pemulihan

LANGKAH EKSEKUSI

Template pre-drafted — tinggal disesuaikan saat insiden, bukan disusun dari nol saat panik

Pasal 46(3)

INCIDENT

Phase 2

KETENTUAN INTI

Dalam hal tertentu wajib beritahu masyarakat luas

LANGKAH EKSEKUSI

Tentukan threshold internal: breach > X user → wajib pengumuman publik

Best Practice

DEV

Disarankan

KETENTUAN INTI

Tidak eksplisit di UU, tapi krusial untuk memenuhi SLA 3×24 jam di atas

LANGKAH EKSEKUSI

Monitoring/alerting: anomaly detection akses data massal, failed login spike — deteksi cepat

6

Transfer Data ke Pihak Ketiga

Broker lain, PAMM manager, signal follower — kapan boleh, kapan butuh consent tambahan

Pasal 16(1)e

DEV

Wajib

KETENTUAN INTI

Transfer/penyebarluasan data = bagian dari "pemrosesan" yang diatur UU

LANGKAH EKSEKUSI

Fitur baru yang kirim data keluar sistem → wajib cek ulang consent flow (lihat Bagian 1)

Pasal 55

DEV

Phase 2

KETENTUAN INTI

Transfer dalam wilayah RI — kedua pihak wajib tetap terapkan perlindungan sesuai UU

LANGKAH EKSEKUSI

Buat **Data Processing Agreement (DPA)** dengan broker/PAMM lokal mitra

Pasal 56(2-4)

PRE-LAUNCH

Wajib

KETENTUAN INTI

Transfer luar negeri — perlu negara setara, atau binding safeguard, atau consent eksplisit tambahan

LANGKAH EKSEKUSI

Dokumentasikan lokasi hosting semua mitra (broker asing, Pusher).
Jika tidak yakin setara → minta consent tambahan

Pasal 65(2)

DEV

Phase 2

KETENTUAN INTI

Larangan ungkap data melawan hukum — pidana hingga 4 tahun

LANGKAH EKSEKUSI

Anonimisasi signal feed publik: tampilkan username/alias, bukan nama asli, kecuali user setuju eksplisit

7

Data Anak & Penyandang Disabilitas

Relevan jika target user mencakup kelompok ini

Pasal 25

DEV

Disarankan

KETENTUAN INTI

Pemrosesan data anak wajib persetujuan orang tua/
wali

LANGKAH EKSEKUSI

Age-gate di registrasi — platform trading umumnya sudah exclude
di bawah 18, pastikan eksplisit di T&C + validasi umur

8

Retensi & Penghapusan Data

Data tidak boleh disimpan selamanya "just in case"

Pasal 16(2)g

DEV

Phase 2

KETENTUAN INTI

Data wajib dihapus/dimusnahkan setelah masa retensi berakhir

LANGKAH EKSEKUSI

Definisikan retention policy per jenis data: password (hapus saat disconnect), transaksi (sesuai kewajiban pajak/OJK), log (1-2 tahun)

Pasal 44

LIVE

Phase 2

KETENTUAN INTI

Wajib musnahkan data jika retensi habis & tidak terkait proses hukum

LANGKAH EKSEKUSI

Scheduled job (cron) untuk purge data sesuai retention policy

Pasal 53

PRE-LAUNCH

Phase 2

KETENTUAN INTI

Wajib tunjuk petugas Pelindungan Data Pribadi jika: layanan publik, skala besar, atau data spesifik skala besar

LANGKAH EKSEKUSI

Untuk startup kecil, cukup 1 orang (founder/CTO) sebagai penanggung jawab — formalkan saat tim membesar

Pasal 54

LIVE

Phase 2

KETENTUAN INTI

Tugas petugas: informasi & saran, pantau kepatuhan, DPIA, jadi narahubung

LANGKAH EKSEKUSI

Petugas ini bertanggung jawab update dokumen compliance ini secara berkala



Ringkasan Prioritas per Fase Roadmap

Checklist siap-pakai selaras dengan tahapan produk Anda

TAHAP 1

MVP

Dashboard + Manual Signal

- ✓ Consent granular (Bagian 1)
- ✓ Enkripsi password + secrets mgmt
- ✓ DPIA dasar
- ✓ Delete account flow
- ✓ Incident response playbook
- ✓ Dokumentasi lokasi hosting

TAHAP 2

Phase 2

Auto-Signal + User MT5

- ✓ Update DPIA untuk profiling otomatis
- ✓ Data access/koreksi self-service
- ✓ Audit log akses data sensitif

TAHAP 3

Phase 3

Auto-Copy Trading

- ✓ Evaluasi ulang DPIA — level risiko naik
- ✓ Consent lebih spesifik untuk eksekusi otomatis (bukan sekadar "lihat signal")

Yang Perlu Dipantau ke Depan

RPP PDP dan Badan PDP masih dalam proses finalisasi (per April–Mei 2026, tinggal tahap akhir pengesahan). Setelah terbit, kemungkinan ada: format DPIA resmi/baku, parameter pasti kapan wajib menunjuk DPO formal, dan kanal pelaporan breach resmi ke Badan PDP (bukan lagi ke Kemkomdigi).

Rekomendasi: cek berkala ke jdih.komdigi.go.id atau pdp.id untuk update pengesahan, dan sesuaikan dokumen ini begitu PP resmi terbit.